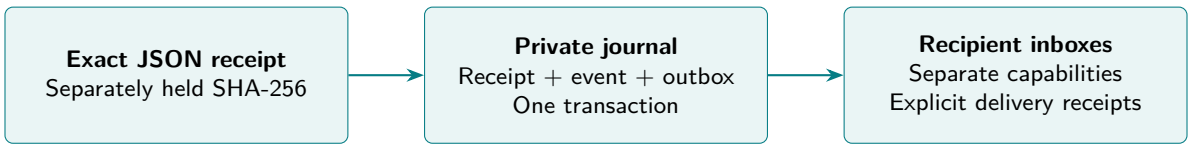
01 / FUNCTIONAL AND ADVERSARIAL CHECKS

Evidence can survive a restart. Delivery stays explicit.

The existing signed exchange passes its tests. A new private observer now retains exact receipts, deduplicates observations and tracks each recipient's delivery. It preserves existing ownership and gates. This is the first local coordination component, not a deployed fleet scheduler or human-signing service.



Implemented data flow in `integrations/workstreams`. A hash match establishes byte identity; the observer does not authenticate receipt claims or infer human awareness.

321 tests passed locally

Suite	Passed
Rust workspace, all features and locked dependencies	167
Gateway / web boundary tests	22 / 2
Literature / offline DFT guard and stub worker	70 / 10
Actual pinned PoX adapter	10
Workstream observer	40
Total	**321**

Gateway and web typechecks and production builds passed. Scoped federation/PoSyn Clippy passed with warnings denied. Synthetic journeys added 27 federation, 14 PoX/Rust and 12 observer checks. No scientific calculation or live payment was qualified by these tests. Public CI explicitly skips the five PoX tests that require its separately installed private source.

Recovery and corruption were exercised

Six processes submitting the same observation produce one event. Killing a writer before commit leaves no partial event or delivery. Restart restores pending inbox items. Capabilities cannot cross recipient or journal boundaries. Files reject shared permissions, wrong ownership, symlinks and hardlinks; input JSON has strict size, depth and value bounds.

Independent review found that a malformed stored timestamp could hide pending delivery and a malformed token hash could raise a type error. Both now fail closed before inbox filtering or authentication, with regression tests.

A real second-machine check passed. A second Mac ran the 40 observer tests and both observer/federation journeys. A synthetic package signed on the first Mac was transferred with pinned hashes, verified on the second and recorded in its observer. Signing secrets stayed on the source; temporary canary state was removed.

Three-host readiness remains bounded

The intended Windows host answered SSH but rejected unattended authentication; its worker and job state remain unverified. Current private-file handling is Unix-only. Windows needs a qualified adapter. Two-machine tests do not establish independent human participation, always-on operation or fleet execution authority.

02 / DEPENDENCIES AND AUTHORITY

Known findings addressed. Remaining boundaries visible.

Point-in-time advisory scan	Before	After
Gateway npm production: affected package entries	10	0
Web npm production: affected package entries	8	0
Rust: applicable package/version findings	5	0*
Python: 14 pinned requirements	0	0

Evidence: `VALIDATION.json`. Counts are package entries, not unique exploits. Both full npm audits also report zero known vulnerabilities.

*Rust retains one raw aggregate finding, excluded only after primary-source range review below.

Small dependency changes, retested behavior

The gateway stays on Express 4, now 4.22.3, with Zod 4.6.7 and patched parser/proxy dependencies. Next is 16.4.3 with patched Sharp, PostCSS and related dependencies. Unused optional x402 SDKs and unused web validators were removed; live payments remain unavailable and fail closed. A new compressed-request test confirms malformed trailing bytes produce a generic HTTP 400 and leave the gateway responsive.

The Rust lock pins Quinn 0.11.18, Rustls 0.23.46, rustls-webpki 0.103.16, webpki-roots 1.0.10 and Tokio 1.53.3. The updated workspace's 167 tests and scoped Clippy passed; the federation binary was rebuilt. The final OSV scan covers 175 registry package versions. Python's 14 pinned requirements passed pip-audit with no known vulnerabilities and no skips.

An explicit advisory correction. OSV's remaining raw hit treats `block-buffer 0.10.4` as affected below 0.12.1. The maintainer explicitly limits the affected range to `>=0.11.0,<0.12.1`. Our locked 0.10.4 is outside that range. The raw hit and reasoning are retained; this is not a blanket package suppression or a claim that every dependency is free of undiscovered flaws.

CI now checks the added boundary

Actions use verified upstream commit SHAs, checkout does not persist credentials, token permissions remain read-only, and jobs have explicit timeouts. Linux and macOS run observer tests and its synthetic journey; gateway and web have production npm audit gates. Local Node 25.9 and Rust 1.89 differ from hosted Node 22 and Rust stable, so hosted CI supplies a separate compatibility check.

Authority the observer deliberately does not acquire

The calling OS account remains trusted. A same-account AI can access its files; human-only acknowledgment needs a separate account or a presence-enforcing signer. Journal hash chains detect corruption, not a malicious same-account rewrite. Recipient tokens grant delivery access only. Records keep human awareness unknown and receipt claims unverified; existing boards remain gate and ownership authority.

Token rotation, live backup/restore, distributed claims, execution grants, Windows support and private push delivery remain later work. No contracts, production services, scientific jobs or external messages were added. Private databases and host credentials are excluded from the public branch.

Reproduce and inspect

Run `python3 -m integrations.workstreams.demo` on Unix with Python 3.10+. The observer README supplies CLI setup and limits. This packet includes editable `REVIEW.md`/`REVIEW.tex`, this PDF and a source-bound validation record. Local evidence binds exact file hashes; branch Actions provide hosted results.

Primary sources: proxy-addr; Zod; Next.js; body-parser; RustCrypto affected range; GitHub secure-use guidance. Full details and evidence boundaries: `REVIEW.md` and `VALIDATION.json`.